

TECHNICAL SECURITY SPECIFICATIONS VMWARE
ESXI 6.X AND 7.0

AUTHOR(S) : Roland Wittmann/Mangesh Kulkarni/Nizammudin Shaikh
DOCUMENT NUMBER : MSP-GAD-0277
VERSION : 2.0
STATUS : Final
SOURCE : Atos
DOCUMENT DATE : 19 November 2020
NUMBER OF PAGES : 23

OWNER : Ritesh Sinha

Role	Signature
Document Owner	26-11-2020 X Ritesh Sinha Sinha, Ritesh Global Service Architect Signed by: Ritesh Sinha
Reviewer	27/11/2020 X Magdalena Zabrocka Magdalena Zabrocka Global Operation Security Compliance Officer Signed by: Magdalena Zabrocka
Quality Assurance Function	26/11/2020 X Approved Magdalena Gondek IDM Documentation Controller Signed by: Magdalena Gondek
Senior Manager	27/11/2020 X Approved Dorin Vlas Head of Risk Management and Control Fra... Signed by: Dorin Vlas

Contents

List of changes	3
Terms and abbreviations.....	5
1 General Information	6
1.1 Purpose	6
1.2 Audience.....	6
1.3 Scope	6
1.4 Implementation of measures	6
1.5 Document maintenance and distribution.....	6
1.6 Related documents.....	7
2 Introduction	9
2.1 Risk Classifications	9
2.2 Deviations	9
3 Description of Measures	10
3.1 User Management and Access Control.....	10
3.2 Network Security	13
3.3 Host Security and Logging.....	16

List of changes

version	Date	Description	Author(s)
1.0	01-08-2018	VMware ESXi 6.5 TSS Initial Release	Roland Wittmann
1.1	10-30-2019	Rereview VE00005 command line change	Roland Wittmann
1.2	27-01-2020	Security review	M. Zabrocka
1.3	28-05-2020	VMware ESXi 6.7 and 7.0 Updated, VE00004	Mangesh Kulkarni
1.4	08-06-2020	Replied to questions for M.Zabrocka and R. Nair, fixed URLs, TLS version fixes, fixed Atos baseline reference	Ritesh Sinha
1.5	25-06-2020	Security review	R. Nair, M. Zabrocka
1.6	08-07-2019	Updated VE00004 with VMware Cli Cmdlets to define the Updated VE00008 with in Exception area for Certain products e.g. Citrix Netscaler Updated VE00014 with TLSv1.2 Measure	Nizamuddin Shaikh
1.7	09-07-2020	Next Security review	M. Zabrocka
1.8	10-07-2020	Updated Implement section with relevant information with Vendor recommended practice for Measure ID VE00014	Nizamuddin Shaikh
1.9	17-07-2020	Security Review – AHS	M. Zabrocka
1.10	07-08-2020	Reviewed the Comments of VE00014 and updated the comments response with inputs	Nizamuddin Shaikh
1.11	12-08-2020	Updated Header & Footer in first page	Ankita Shrivastava
1.12	28-08-2020	Security Review – AHS	M. Zabrocka
1.13	01-09-2020	Removed Typo from VE00009's implementation plan and updated GOSCO comments for VE00014	Nizamuddin Shaikh
2.0	19-11-2020	Criticality reviewed and measure ID prefix completed Final Quality assurance	M. Zabrocka M. Gondek

Target readers, communication method

Target group	Distribution / publication method
Designers, architects and administrators tasked with validation and implementation of the security baselines.	The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG) on SharePoint https://sp2013.myatos.net/ms/gd/gadp/TSSD/

Terms and abbreviations

Terms / Abbreviations	Description
ATLM	Atos Technology Lifecycle Management
GADP	Global Architecture and Delivery Processes
BDS	Atos Big Data & Security Tower
IDM	Atos Infrastructure & Data Management Tower
GOSCO	Global Operation Security Compliance Officer
RAF	Risk Acceptance Form
RFC	Request for Comments
SLA	Service Level Agreements
TSS(D)	Technical Security Specifications (Document)
VM	Virtual Machine

1 General Information

1.1 Purpose

A Technical Security Specification (TSS) is the document that can be seen as a result of the translation of the Atos IT Security Controls as described in the Security Baselines to specific Technical Security Controls.

This document holds the definitions of the security measures corresponding to the Technical Security Controls for a specific device or software area. The document contains details about how to configure the target devices and software and what needs to be validated for checking the compliancy to that measure.

The document also details on the risk classification and the data and data sources required for an IT Security Control.

1.2 Audience

This document is intended for designers, architects and administrators tasked with validation and implementation of the security baselines as per IT Security Control Framework.

The document assumes that the reader has reasonable understanding of the Security Compliance Process as well as familiarity with the devices/software mentioned in this document.

1.3 Scope

The scope of this Technical Security Specification covers the following:

- ▶ VMware ESXi 6.x and 7.0

The following areas are explicitly out of scope:

- ▶ All other VMware released SW products
- ▶ Other versions of VMware ESXi

1.4 Implementation of measures

The implementation of the TSS measures is mandatory for all target devices and software mentioned in the scope. In case of implementation in existing environments, TSS measures must be tested first in pre-production test environments following applicable change management processes before implementation in production.

Some of the measures in this document may affect compliance to industry specific regulations. In this case the security officer must approve the implementation or create an exception.



All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer.

1.5 Document maintenance and distribution

The TSS document, when approved, published and validated, becomes procedural to all referenced systems, services, applications or processes managed by Atos Infrastructure & Managed Data (I&DM) following a 120 days grace period, during which an analysis of gaps, documentation of exceptions, and a plan to bring non-compliant systems into compliance must be developed.

The maintenance of the document is performed by the Global Service Architect. TSS documents will be reviewed minimally on an annual basis, unless technical or business requirements dictate updating sooner.

1.6 Related documents

This document is a subset of Atos Technology Lifecycle Management (ATLM) artefacts. Related documents are captured in below table.

Reference	Document Name
MSM-GSS-0001	Security Management Baseline
MSM-GSS-0002	Logical Security Baseline
MSM-GSS-0003	Network Device Security Baseline
MSM-GSS-0006	Server Security Baseline
ASM-SEC-0006	Password Policy
ASM-SEC-0001	ATOS INFORMATION SECURITY POLICY
TSS MeasureIDs (V...	Name conventions and allocated Measure ID's

Table 1: ATLM Related Documents

A number of vendor best practice documentation has been used in this TSS as per next table.

This document is a subset of VMWare Inc., vendor security baseline related documents are captured below in **Table 1**.

Vendor	Document Name
VMware Inc.,	https://www.vmware.com/content/dam/digitalmarketing/vmware/en/files/xls/vmware-6.5-security-configuration-guide-ga-13-apr-17.xlsx
VMware Inc.,	VMware KB 1012382
VMware Inc.,	http://kb.vmware.com/kb/2017193
VMware Inc., Forged Transmits	VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
VMware Inc., Promiscuous Mode	VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
VMware Inc., Acceptance Levels of Hosts and VIBs	VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
VMware Inc., Disable TLS	VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0

Vendor	Document Name
	https://kb.vmware.com/s/article/2147469
VMware Inc., Secuirty Guide	vSphere Security VMware vSphere 6.7, 7.0, VMware ESXi 6.7, 7.0, VMware-vSphere 6.7 VMware-vSphere 7.0

Table 2: Vendor documentation

2 Introduction

The 'Technical Security Specification for VMware ESXi 6.x and 7.0' is a mandatory supplement to the existing Atos Security Policy and IT Security Controls. Its purpose is to increase security for IT systems, and it must be implemented for all Atos managed devices. The measures and their priorities described here may be tightened and supplemented as necessary.

The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG). The TSS itself is coordinated with reviewers from the Global Security Services and all relevant Atos Global Delivery units. It aims at providing sufficient detail to allow a qualified administrator to implement all measures.

To assist in documentation, a checklist for the manual validation process has been prepared as part of this TSS in appendix A.

Further assurance about the compliance of a device or software to the Atos IT Security Controls can be gained via a Scan on Demand as part of the Vulnerability Management Service offered Atos Big Data & Security (BD&S).

2.1 Risk Classifications

Each confirmed measure is assigned a risk level (Critical, Moderate, or Low) corresponding to its potential impact on the security of Atos service delivery and devices/software in scope.

CRITICAL

A security control is critical if it can be exploited by a remote attacker to gain access to the system, data or functionality when not implemented. All critical controls must be implemented before the equipment is installed in a production environment.

MODERATE

A security control is rated moderate if it can compromise data or functionality on the network equipment only if some other condition is met (e.g. a particular module or a user within a particular role is required). Moderate issue security bulletins typically include recommended actions to resolve the issue.

LOW

A security control is rated low if it is very difficult to exploit from outside or has a limited potential impact.

2.2 Deviations

Deviations to the measures must be corrected according to customer agreed Service Level Agreements (SLA). Atos will use default resolution targets for correcting the deviations that must be confirmed or changed by each customer.

Because correcting a deviation may impact the customer's business process, the analyst must decide whether or not the customer should be consulted. If the customer does not agree with correcting a deviation because doing so will negatively impact his business, a Risk Acceptance Form (RAF) has to be signed and handed over to formally transfer the associated risks to the customer. Atos will retain the right to accept or challenge the customer exception request.

3 Description of Measures

All measures in this document are categorized as MANDATORY. This categorization means that implementation is absolutely required. Exceptions other than those explicitly declared inside a measure require approval by DBS and GADP.

The key words 'MUST', 'MUST NOT', 'REQUIRED', 'SHALL', 'SHALL NOT', 'SHOULD', 'SHOULD NOT', 'RECOMMENDED', 'MAY', and 'OPTIONAL' in this document are to be interpreted as described in RFC 2119 (<https://www.ietf.org/rfc/rfc2119.txt>).

All measures are grouped into specific areas. The specific areas are chosen to combine measures where the IT Security Control can be divided into multiple measures, e.g. 'Updates and Patches', 'User Management and Access Control' and 'Protocols and Services'.

3.1 User Management and Access Control

Measure ID	3VE00001
Measure Title	Securely Auto Unlock Account
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 - 2.1.10
Background	When an account gets 'locked out' by too many wrong password attempts, it remains 'locked out' for 1800 seconds.
Measure	Set Time To Securely Auto Unlock Account
Implementation	From the vSphere Web Client select the host, click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System Settings'. Enter 'Security.AccountUnlockTime' in the filter. Verify that the value for this parameter is set to 1800. The value 1800 is the duration in seconds to keep the account 'locked out' after exceeding the maximum allowed failed login attempts. From the vSphere Web Client select the host, click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System Settings'. Enter 'Security.AccountUnlockTime' in the filter. Click edit and set the value for this parameter to 1800. VMware-vSphere 6.5 And VMware-vSphere 7.0
Exception	None
First Appearance	31-08-2017

Measure ID	1VE00002
Measure Title	Security Auto Unlock Account – Max Attempts
Classification	LOW
Baseline Reference	MSM-GSS-0002 - 2.1.10

Background	After 3 failed logins the account will be locked out.
Measure	Set Time To Securely Auto Unlock Account – Max Attempts
Implementation	From the vSphere Web Client select the host, click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System Settings'. Enter 'Security.AccountLockFailures' in the filter. Verify that the value for this parameter is set to 3. The value of 3 is the Maximum allowed failed login attempts before locking out a user's account. From the vSphere Web Client select the host, click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System Settings'. Enter 'Security.AccountLockFailures' in the filter. Click edit and set the value for this parameter to 3. VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None
First Appearance	31-08-2017

Measure ID	3VE00003
Measure Title	Set Time To Securely Auto Terminate Idle ESXi 6.x and 7.0 Shell and SSH Sessions
Classification	CRITICAL
Baseline Reference	MSM-GSS-0003 - 2.1.10
Background	Logins to the Host either via ESXi Shell or ssh must be terminated after 900 seconds of being idle.
Measure	Set Time To Securely Auto Terminate Idle ESXi 6.x and 7.0 Shell and SSH Sessions
Implementation	From vSphere web client, select host and then click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System settings'. Filter for UserVars.ESXiShellInteractiveTimeout And UserVars.ESXiShellTimeout to see the configured value. Verify that the value for this parameter is set to 900. The value of 900 is the idle time before an interactive shell is automatically logged out (in seconds). Takes effect only for newly logged in sessions. ESXi Shell Command Remediation # esxcli system settings advanced set -o /UserVars/ESXiShellInteractiveTimeout -i 900 esxcli system settings advanced set -o /UserVars/ ESXiShellTimeout -i 900

	Note: When SSH server is started default protocol version is 2. DO NOT CHANGE THIS! http://kb.vmware.com/kb/2004746
Exception	None
First Appearance	31-08-2017

Measure ID	3VE00004
Measure Title	Securely Set Audit DCUI Timeout Value
Classification	CRITICAL
Baseline Reference	ASM-SEC-0001 - 3.6.2.1
Background	When logged in to DCUI (Direct Console User Interface) to ESXi 6.x and 7.0 the session will be logged out after being idle 600 seconds.
Measure	Audit DCUI Timeout Value
	From the vSphere Web Client select the host, click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System Settings'. Enter 'UserVars.DcuiTimeOut' in the filter. Verify that the value for this parameter is set to 600. 600 is the idle time in seconds before DCUI is automatically logged out. From the vSphere Web Client select the host, click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System Settings'. Enter 'UserVars.DcuiTimeOut' in the filter. Click edit and set the value for this parameter to 600 or more restrictive. Using PowerCLI : Get-VMHost Get-AdvancedSetting -Name UserVars.DcuiTimeOut Set-AdvancedSetting -Value 600 https://www.vmware.com/content/dam/digitalmarketing/vmware/en/files/xls/vmware-6.5-security-configuration-guide-ga-13-apr-17.xlsx
Exception	None
First Appearance	31-08-2017

3.2 Network Security

Measure ID	1VE00005
Measure Title	Enable BPDU Filter On The ESXi 6.x and 7.0 Host To Prevent Being Locked Out Of Physical Switch Ports with Portfast and BPDU Guard Enabled
Classification	LOW
Baseline Reference	No baseline reference
Background	Prevents that Bridged Protocol Data Units (BPDUs) are sent to physical switches by a VM. This could cause the physical switch to disable the switch port.
Measure	Enable BPDU Filter On The ESXi 6.x and 7.0 Host To Prevent Being Locked Out Of Physical Switch Ports with Portfast and BPDU Guard Enabled
Implementation	From vSphere Web Client, select the host and then click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System settings'. Filter for Net.BlockGuestBPDU to see the configured value. 1 is the Block guest sourced BPDU frames and only configured value. From vSphere Web Client, select the host and then click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System settings'. Filter for Net.BlockGuestBPDU to see the configured value. Click edit and set it to the configured value 1. ESXi Shell Command Implementation esxcli system settings advanced list -o /Net/BlockGuestBPDU ESXi Shell Command Remediation esxcli system settings advanced set -o /Net/BlockGuestBPDU -i 1 http://kb.vmware.com/kb/2017193 http://kb.vmware.com/kb/2047822 VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0 https://blogs.vmware.com/vsphere/2018/11/announcing-the-vsphere-6-7-update-1-security-configuration-guide.html
Exception	None
First Appearance	31-08-2017

Measure ID	1VE00006
Measure Title	Securely Set The 'Media Access Control (MAC)' address Policy To Reject
Classification	LOW
Baseline Reference	No baseline reference
Background	When the Mac address changes option is set to Reject, ESXi does not honor requests to change the effective MAC address to a different address than the initial MAC address

Measure	Ensure That The ' <i>Media Access Control (MAC)</i> ' address Policy Is Set To Reject
	From the vSphere web client select the host and click '<i>Manage</i>' -> '<i>Networking</i>' -> '<i>Virtual Switches</i>'. For each Standard switch and for each port group within that virtual switch, click edit. Go to '<i>Security</i>' and verify that '<i>MAC address changes</i>' is set to '<i>Reject</i>'. From vSphere web client, for each portgroup within each virtual switch go to '<i>Manage</i>' -> '<i>Settings</i>' -> '<i>Policies</i>' and click '<i>Edit</i>'. Go to '<i>Security</i>' and set the '<i>MAC address changes</i>' policy to '<i>Reject</i>' VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None
First Appearance	31-08-2017

Measure ID	1VE00007
Measure Title	Securely Configure The ' <i>Forged Transmits</i> ' Policy Is Set To Reject
Classification	LOW
Baseline Reference	No baseline reference
Background	To protect against MAC impersonation, you can set the Forged transmits option to Reject
Measure	Ensure That The ' <i>Forged Transmits</i> ' Policy Is Set To Reject
Implementation	From the vSphere Web Client select the host and click '<i>Manage</i>' -> '<i>Networking</i>' -> '<i>Virtual Switches</i>'. For each standard virtual switch and for each port group within that standard virtual switch, click edit. Go to '<i>Security</i>' and verify that '<i>Forged Transmits</i>' is set to '<i>Reject</i>'. From vSphere Web Client, for each portgroup within each standard virtual switch go to '<i>Manage</i>' -> '<i>Settings</i>' -> '<i>Policies</i>' and click '<i>Edit</i>'. Go to '<i>Security</i>' and set the '<i>Forged transmits</i>' policy to '<i>Reject</i>'. http://kb.vmware.com/kb/2017193 VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None
First Appearance	31-08-2017

Measure ID	1VE00008
Measure Title	Ensure That The ' <i>Promiscuous Mode</i> ' Policy Is Set To Reject
Classification	LOW
Baseline Reference	MSM-GSS-0003 Section 2.3.10

Background	Although promiscuous mode can be useful for tracking network activity, it is an insecure mode of operation, because any adapter in promiscuous mode has access to the packets even if some of the packets are received only by a particular network adapter.
Measure	Ensure that the ' <i>Promiscuous Mode</i> ' policy is set to reject
Implementation	From the vSphere Web Client select the host and click '<i>Manage</i>' -> '<i>Networking</i>' -> '<i>Virtual Switches</i>'. For each standard virtual switch and for each port group within that standard virtual switch, click edit. Go to '<i>Security</i>' and verify that '<i>Promiscuous Mode</i>' is set to '<i>Reject</i>'. VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	Note: Certain products e.g. Citrix Netscaler need this feature to be enabled to manage their HA. Exception process must be followed then! <i>Packet capture products use this mode for diagnostics and any approvals for such has to be reviewed thoroughly with NDCS and any traffic generated during such a test should be accounted for. This is critical to prevent network outage.</i>
First Appearance	31-08-2017

3.3 Host Security and Logging

Measure ID	1VE00009
Measure Title	Secure VM Transparent Page Sharing-Intra-VM
Classification	LOW
Baseline Reference	No baseline reference
Background	Sharing of memory pages between VM's shall be disabled to eliminate the theoretical possibility to access the memory.
Measure	Ensure Default Setting For Intra-VM TPS Is correct
Implementation	From the vSphere Web Client, select a host and then click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System settings'. Filter for Mem.ShareForceSalting. Verify that it is set to 2. PShare salting let you limit the transparent page sharing only between a set of VMs. PShare salting is controlled by the VMX sched.mem.pshare.salt option. The PShare salting option has three states: 0 - no salting or isolation between VMs; 1 - VMs that have the sched.mem.pshare.salt option set are able to share memory with VMs with the same salt; 2 - VMs that do not have the sched.mem.pshare.salt option set cannot share memory with any other VM, page sharing is possible only inside the VM. If the sched.mem.pshare.salt is present but empty, the VM gets its own unique salt. From vSphere Web Client, select a host and then click 'Manage' -> 'Settings' -> 'System' -> 'Advanced System settings'. Filter for Mem.ShareForceSalting. Click edit and set it to 2. https://kb.vmware.com/kb/2080735 https://kb.vmware.com/kb/2097593 https://kb.vmware.com/kb/2091682
Exception	None
First Appearance	31-08-2017

Measure ID	3VE00010
Measure Title	Securely Configure Disable Managed Object Browser (MOB)
Classification	CRITICAL
Baseline Reference	No baseline reference
Background	The managed object browser (MOB) provides a way to explore the VMkernel object model. Attackers could use that to perform malicious configuration changes.
Measure	Disable Managed Object Browser (MOB)

Implementation	Open the Web Client, Select the settings for the host, Select 'Advanced System Settings' and search for 'Config.HostAgent.plugins.solo.enableMob'. Ensure the value is False (default in 6.x and later). Open the Web Client, Select the settings for the host, Select 'Advanced System Settings' and search for 'Config.HostAgent.plugins.solo.enableMob' and set the value to False if it isn't currently False. ESXi Shell Command Implementation vim-cmd hostsvc/advopt/view Config.HostAgent.plugins.solo Note: MOB is disabled by default. VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None.
First Appearance	31-08-2017

Measure ID	2VE00011										
Measure Title	Configure the ESXi 6.x and 7.0 Host Firewall Restrictions										
Classification	MODERATE										
Baseline Reference	MSM-GSS-0003 2.5.1 and MSM-GSS-0006 Section 2.5.1										
Background	The ESXi built-in firewall must be used and configured correctly.										
Implementation	From the vSphere web client, select the host and click 'Manage' -> 'Settings' -> 'System' -> 'Security Profile'. Verify that for enabled services, both incoming and outgoing connections, a proper network/IP Range is selected (the 3rd column should not be 'All'). From the vSphere web client, select the host and click 'Manage' -> 'Settings' -> 'System' -> 'Security Profile'. For each enabled services for both incoming and outgoing connections set a proper network/IP Range after deselecting 'Allow connections from any IP address' checkbox. <u>List of ESXi 6.x and 7.0 Security Profile Services which must be disabled:</u> <table> <thead> <tr> <th>Service</th><th>Default</th></tr> </thead> <tbody> <tr> <td>ESXi Shell</td><td>stopped</td></tr> <tr> <td>SSH</td><td>stopped</td></tr> <tr> <td>PC/Sc SmartCard Daemon</td><td>stopped</td></tr> <tr> <td>X.Org Server</td><td>stopped</td></tr> </tbody> </table>	Service	Default	ESXi Shell	stopped	SSH	stopped	PC/Sc SmartCard Daemon	stopped	X.Org Server	stopped
Service	Default										
ESXi Shell	stopped										
SSH	stopped										
PC/Sc SmartCard Daemon	stopped										
X.Org Server	stopped										

	<u>List of ESXi 6.x and 7.0 Security Profile Services which must be enabled (and configured):</u> <table><tr><th>Service</th><th>Default</th></tr><tr><td>NTP Daemon</td><td>Running</td></tr><tr><td>Direct Console UI</td><td>Running</td></tr></table> ESXi Shell Command Implementation #List all services: ls /etc/init.d #get service status: /etc/init.d/[SERVICE] status ESXi Shell Command Remediation # /etc/init.d/[SERVICE] STOP <u>The firewall must be enabled:</u> esxcli network firewall get Default Action: DROP Enabled: true Loaded: true Implementation: esxcli network firewall set --enabled true esxcli network firewall set --default-action false <u>The following firewall ruleset ids must be disabled:</u> http-client FTP-Client SSH-Client SNMP-Server Gdbserver Implementation: esxcli network firewall ruleset set --enabled false --ruleset-id=<string> VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0	Service	Default	NTP Daemon	Running	Direct Console UI	Running
Service	Default						
NTP Daemon	Running						
Direct Console UI	Running						
Exception	None						
First Appearance	31-08-2017						

Measure ID	1VE00012
Measure Title	Securely Configure Persistent Logging For All ESXi 6.x and 7.0 Hosts
Classification	LOW
Baseline Reference	MSM-GSS-0001 - 2.6.5
Background	The logs contain configuration quite a lot of infrastructure details, like IP, MAC,etc. This should be secured. Any leak of this data can lead to information being disclosed that amounts to a security violation as per data protection as well.
Measure	Configure Persistent Logging For All ESXi 6.x and 7.0 Hosts
Implementation	From the vSphere web client select the host and click 'Manage' -> 'Settings' -> 'Advanced System settings'. Look for 'Syslog.global.logDir' parameter name and ensure that it is not set to '[] /scratch/log' or is not blank. 1. Identify the datastore path where you want to place scratch, then login to the vSphere Web Client. 2. Navigating to the host and select 'Manage' and select 'Advanced System Settings' in the System panel. 3. Enter 'Syslog.global.LogDir' in the filter. Set the 'Syslog.global.LogDir' to the desired datastore path. Note: The Syslog.global.LogDir must be set for each host. ESXi Shell Command Implementation # esxcli system syslog config get ESXi Shell Command Remediation # esxcli system syslog config set -logDir http://kb.vmware.com/kb/1033696
Exception	None
First Appearance	31-08-2017

Measure ID	1VE00013
Measure Title	Configure remote logging for ESXi hosts
Classification	LOW
Baseline Reference	ASM-SEC-0001 - 3.9 and MSM-GSS-0001 - 2.6.5
Background	ESXi Logs can be sent to a syslog server.
Measure	Configure Remote Logging for ESXi 6.x Hosts
Implementation	From the vSphere Web Client select the host, click 'Manage' -> 'Advanced System Settings', and enter 'Syslog.global.logHost' in the filter. Check whether a syslog host is set. From the vSphere Web Client select the host and click 'Manage' -> 'Advanced System Settings' and enter 'Syslog.global.logHost' in the filter. Set the 'Syslog.global.logHost' to the hostname of your syslog server. Note: when setting a remote log, host it is also recommended to set the 'Syslog.global.logDirUnique' to true. You must configure the syslog

	settings for each host. The host syslog parameters can also be configured the vCLI or PowerCLI or using an API client. ESXi Shell Command Implementation # esxcli system syslog config get ESXi Shell Command Remediation # esxcli system syslog config set loghost <IP or FQDN> # esxcli system syslog reload VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None
First Appearance	31-08-2017

Measure ID	2VE00014
Measure Title	Disable SSLv3, TLSv1.0, TLSv1.1 and enable TLSv1.2
Classification	MODERATE
Baseline Reference	No baseline reference
Background	SSLv3, TLS v 1.0, 1.1 are insecure and need to be disabled and enable TLS v 1.2.
Measure	Disable SSLv3, TLSv1.0, TLSv1.1 and enable only TLSv1.2
Implementation	Disable In secure protocols SSLv3, TLSv1.0, TLSv1.1 and enable only TLSv1.2 Remediation: see KB https://kb.vmware.com/s/article/2147469 Please Note: A reboot is required to activate the new settings. Remediation: 1. Log in to the vCenter Server system with the user name and password of the vCenter Single Sign-On user who can run scripts. 2. Go to the directory where the script is located. a) On a host that is part of a cluster, run one of the following commands. To disable TLS 1.0 and TLS 1.1 and enable only TLS 1.2 on all hosts in a cluster, run the following command: <pre>reconfigureEsx vCenterCluster -c Cluster_Name -u Administrative_User -p TLSv1.1 TLSv1.2</pre>

	b) To disable TLS 1.0 and TLS 1.1, and enable only TLS 1.2 on all hosts in a cluster, run the following command: <pre>reconfigureEsx vCenterCluster -c Cluster_Name -u Administrative_User -p TLSv1.2</pre> c) On an individual host, run one of the following commands. To disable TLS 1.0 and TLS 1.1 Both and enable TLS 1.2 on an individual host, run the following command. <pre>reconfigureEsx vCenterHost -h <ESXi_Host_Name> -u Administrative_User -p TLSv1.2</pre> Note: To reconfigure a standalone ESXi host (one that is not part of a vCenter Server system): <pre>reconfigureEsx ESXiHost -h <IP1> <IP2> -u root -p TLSv1.2</pre> To disable TLS 1.0 and TLS 1.1, and enable only TLS 1.2 on an individual host, run the following command. <pre>reconfigureEsx vCenterHost -h <ESXi_Host_Name> -u Administrative_User -p TLSv1.2</pre> Reboot the ESXi host to complete the TLS protocol changes. https://www.vmware.com/content/dam/digitalmarketing/vmware/en/files/xls/vmware-6.5-security-configuration-guide-qa-13-apr-17.xlsx https://docs.vmware.com/en/VMware-vSphere/6.7/com.vmware.vsphere.security.doc/GUID-BDCE47DD-8AD2-4C98-94FF-7769D0BEE1C2.html VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	
First Appearance	08-11-2017

Measure ID	1VE00015
Measure Title	Verify Image Profile and VIB Acceptance Levels
Classification	LOW
Baseline Reference	No baseline reference
Background	Defines which vib are allowed to install. With 'Partner Supported' only vib's can be installed which are signed by VMware or VMware Certified partners.
Measure	Verify Image Profile and VIB Acceptance Levels set to PartnerSupported

Implementation	Verify the ESXi Image Profile to only allow signed VIBs. An unsigned VIB represents untested code installed on an ESXi host. The ESXi Image profile supports four acceptance levels: (1) VMwareCertified - VIBs created, tested and signed by VMware (2) VMwareAccepted - VIBs created by a VMware partner but tested and signed by VMware, (3) PartnerSupported - VIBs created, tested and signed by a certified VMware partner (4) CommunitySupported - VIBs that have not been tested by VMware or a VMware partner. Community Supported VIBs are not supported and do not have a digital signature. To protect the security and integrity of your ESXi hosts do not allow unsigned (CommunitySupported) VIBs to be installed on your hosts. Remediation: From vSphere web client, select host and then click 'Configure' -> 'System' -> 'Security Profile'. Scroll down until you see 'Host Image Profile Acceptance Level'. Verify that the 'Acceptance Level' parameter is set to 'VMware Accepted', 'VMware Certified' or 'Partner Supported'. Esxcli: Retrieving the Acceptance Level: esxcli software acceptance get Setting the Acceptance Level: esxcli software acceptance set --level PartnerSupported VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	
First Appearance	08-11-2017

Appendix A Checklist

Device Name	
--------------------	--

Measure ID	Measure title	Alcatraz	Checked
3VE00001	Securely Auto Unlock Account	NO	
1VE00002	Security Auto Unlock Account – Max Attempts	NO	
3VE00003	Set Time to Securely Auto Terminate Idle ESXi 6.x and 7.0 Shell and SSH Sessions	NO	
3VE00004	Securely Set Audit DCUI Timeout Value	NO	
1VE00005	Enable BPDU Filter On The ESXi 6.x and 7.0 Host To Prevent Being Locked Out Of Physical Switch Ports with Portfast and BPDU Guard Enabled	NO	
1VE00006	Securely Set The 'Media Access Control (MAC)' address Policy To Reject	NO	
1VE00007	Securely Configure The 'Forged Transmits' Policy Is Set To Reject	NO	
1VE00008	Ensure That The 'Promiscuous Mode' Policy Is Set To Reject	NO	
1VE00009	Secure VM Transparent Page Sharing-Intra-VM	NO	
3VE00010	Securely Configure Disable Managed Object Browser (MOB)	NO	
2VE00011	Configure the ESXi 6.x and 7.0 Host Firewall Restrictions	NO	
1VE00012	Securely Configure Persistent Logging for All ESXi 6.x and 7.0 Hosts	NO	
1VE00013	Configure remote logging for ESXi hosts	NO	
2VE00014	Disable SSLv3, TLSv1.0, TLSv1.1 and enable TLSv1.2	NO	
1VE00015	Verify Image Profile and VIB Acceptance Levels set to PartnerSupported	NO	